VITALGUARD DB 감사 — 1페이지 경영요약

감사일 2026-06-28 · **대상** 정적 DDL 11개 + 앱 DB 코드 · **라이브 미연결**

한눈에 보기

지표	값
전체 건강점수	**46/100** (상용화 전 시정 필수)
컴플라이언스 점수	**28/100**
Critical / High / Medium	**1 / 9 / 22**
예상 총공수	**약 96시간** (P0~P2 약 2.5주)

핵심 메시지

DB 계층 방어(RLS·암호화·접속로그·GRANT/REVOKE)가 **전부 0건**이다. 현재 멀티테넌트 격리와 민감정보 보호가 **전적으로 앱 코드 단일 의존**이라, DB 직접접속·신규 라우트 한 곳만 우회하면 작업자 건강·생체·위치가 평문으로 노출된다. 이것이 최대 구조적 리스크다.

긍정 소견. 앱 인증(users)은 scrypt 해시·fail-closed·IP 잠금 양호. 전 경로 파라미터라이즈드로 SQL 인젝션 표면 없음. 주민번호 컬럼 없음. SECURITY DEFINER 0건.

Top 5 우선순위

순위	항목	심각도	공수
1	민감정보(건강·생체·위치) 평문 + DB 보호 전무	Critical	26h
2	T_SAFEGUARD.SG_PWD 평문 가능 설계	High	3h
3	백업/복구 기반 자체 부재 (영구손실 위험)	High	8h
4	FK 6개 + T_SENSING 시계열 인덱스 전무	High	1.5h
5	시계열 리텐션·파티셔닝·VACUUM 자동화 부재	Medium	6h

컴플라이언스 (개인정보보호법)

민감정보 암호화·접속기록(pgaudit)·보유기간/파기·가명처리·동의기록·SSL — **6개 영역 모두 미준수**. 제23조·제29조 위반 시 과징금·형사처벌 대상. KOSHA 산재자료 보존(추정 3년)은 백업 부재로 충돌.

1주차 즉시 조치 (P0, 약 14.5h)

백업 자동화(4h) · SG_PWD 해시 CHECK(3h) · FK/시계열 인덱스(1.5h) · 풀 타임아웃(0.5h) · calendar FK(1h) · pgcrypto+암호화 컬럼 1단계(4.5h).

> 모든 CHECK 추가 전 진단쿼리로 기존 데이터 위반 0 을 확인하고, 평문/SSL/권한 등 라이브 종속 항목은 운영 실태 확인 후 최종 결론을 낼 것.